GRC206 Assignment: Design a Security Awareness Program
NAME: Omotayo Akinola
STUDENT ID: 2025/GCR/12813
EMAIL: gcr2512813@students.icdfa.edu.ng

Northbridge Logistics: 12 Month Security Awareness Program

Introduction. This report designs a 12 month program for Northbridge Logistics (800 staff across head office, warehouses and remote sales) using the five stage lifecycle. Scenario facts are marked (Scenario). My proposals, assumptions and targets are marked (Proposal), (Assumption) and (Proposed target), and are planning choices, not existing Northbridge results.

Task 1: Assess

1.1 Top three human driven risks

Risk 1: Staff act on fraudulent invoice or payment change requests. Justification (Scenario): recent invoice fraud attempts. Impact: direct financial loss. Unsafe action: paying or changing bank details from an emailed request without checking. Safer action (Proposal): verify by calling a known number, with a second approver.

Risk 2: Password reuse. Justification (Scenario): two staff reused passwords after a breach. Impact: one stolen password can unlock several systems. Unsafe action: using the same password across accounts. Safer action (Proposal): unique passwords in a password manager, with multi factor authentication.

Risk 3: Mishandling of regulated customer data. Justification (Scenario): the company handles regulated customer data. Impact: regulatory penalties, customer harm and reputational damage, so this is the highest severity risk. Unsafe action: sharing or storing data outside approved systems, sending it to the wrong person, or leaving it visible. Safer action (Proposal): use approved channels, share the minimum, report mistakes quickly.

1.2 Audience segments

Audience	Touches	How they work	Risks	Needs
Head office	Email, documents, customer data	Desk based, email heavy	2, 3	Spotting phishing, password habits, safe sharing
Warehouse	Customer addresses, delivery records, scanners	On the floor, little email time	3, 2	Very short, practical guidance within shifts

Remote sales	Customer contacts, quotes, contracts	Laptops and phones off site	3, 2	Safe devices and networks, phishing on mobile
Finance	Invoices, bank details, payment approvals	Desk based, time pressure	1, 2	A practised payment verification routine

1.3 Pre launch baseline (Proposal). The scenario gives no measurements, so these are collected before launch, with sources in brackets:

1. Click and report rates in one baseline phishing simulation (simulation tool). Risks 1, 2.
2. Fraud attempts received, caught and paid (finance records, incident log). Risk 1.
3. Staff with reused or breached passwords, and multi factor coverage (identity system, breached password check). Risk 2.
4. Customer data incidents in the past 12 months (incident log, data protection contact). Risk 3.
5. A short awareness survey, with a paper or QR code version for warehouse shifts (survey results by role and shift). All risks.

Task 2: Plan

2.1 Measurable objectives (all targets are Proposed targets)

1. **Objective 1 (Risk 1).** By the end of month 6, at least 90% of supplier bank detail changes and unusual payments are verified by call back and a second approver. Evidence: monthly sample audit. Owner: Finance Controller.
2. **Objective 2 (Risk 2).** By the end of month 6, at least 95% of accounts have multi factor authentication and accounts with reused or breached passwords have fallen by at least 75% from baseline. Evidence: identity system reports. Owner: IT Security Lead.
3. **Objective 3 (Risk 3).** By the end of month 12, human error data incidents have fallen by at least 30% from baseline and at least 90% are reported within 24 hours. Evidence: incident log. Owner: Data Protection Contact. Reporting may rise early as staff speak up, so the count is read with reporting speed.

2.2 Sponsor and owners (by role). The **Chief Operating Officer** is executive sponsor (Assumption): backs the program, approves budget and staff time, releases warehouse staff, and receives quarterly reports. The **Security Awareness Lead** runs the program, schedules activities and simulations, collects metrics and chairs quarterly reviews. The **Finance Controller, IT Security Lead and Data Protection Contact** each own one objective and control its evidence. The **Warehouse Operations Manager** makes shift briefings possible and passes on shift feedback. The **HR Manager** runs onboarding and records completion.

2.3 Topics by audience

Audience	Topics	Risks
Head office	Spotting phishing, unique passwords and multi factor, safe data sharing	2, 3
Warehouse	Keeping customer details out of sight, never sharing scanner logins, what to do when data goes astray	3, 2
Remote sales	Safe devices and public wifi, protecting data on laptops and phones, phishing on mobile	3, 2
Finance	Payment verification routine, fake invoices and changed bank details, secure logins	1, 2
All staff	Reporting mistakes without blame	1, 2, 3

Task 3: Deliver

3.1 Delivery formats

Audience	Format	Why it fits
Head office	15 minute online modules each quarter, monthly tips, posters	Desk staff can fit short modules, and repetition builds habit
Warehouse	10 minute supervisor led toolbox talks at shift start with a one page card, posters at scanners	Little desk or email time, so learning happens on the floor from trusted supervisors
Remote sales	15 minute recorded virtual sessions each quarter	Staff work across places and time zones
Finance	20 minute quarterly scenario workshops on fake invoices	A procedure is learned by rehearsing it

3.2 Onboarding. Day one: new joiners set up multi factor authentication and the password manager. Week one: a 20 minute session on data handling and reporting (10 minutes within site induction for warehouse joiners). Within 30 days: a role session, such as the payment routine for finance. HR schedules it and the Security Awareness Lead supplies content.

3.3 Phishing simulation approach. One baseline simulation before launch, then about every two months in staggered batches, with themes matching the risks (fake invoices, password reset alerts, requests for customer data). Warehouse staff practise through scenario cards in

toolbox talks. Anyone who clicks sees a 30 second explanation straight away. Results go to managers as group totals, never names, and repeat clickers are offered friendly, optional coaching. Simulations are not used for discipline (Proposal, to be confirmed with HR). A report counts as success and is tracked beside the click rate.

3.4 No blame reporting route. Email staff use a one click “Report suspicious email” button. Staff without regular email use a short phone number or a QR code at scanner stations, and supervisors can report for them. Urgent cases such as payment requests or data sent to the wrong person go to the security team line (out of hours contact is an Assumption). Every report is acknowledged within one working day, urgent cases the same day, with a thank you. The sponsor states in writing that honest mistakes reported promptly will not lead to disciplinary action, while deliberate misconduct is handled separately (Proposal, to be confirmed with HR).

Task 4: Measure

Comparisons use the pre launch baseline from Task 1. Targets are Proposed targets.

Metric and calculation	Source, owner, review	Baseline and target	What a change would mean
1 Reach. Staff completing their assigned activity divided by staff assigned, per audience	Learning, HR and attendance records. Security Awareness Lead, monthly	Starts at zero. 90% in every audience by month 3	Low reach in one audience, especially warehouse, means delivery is failing there
2 Phishing reports and click rates. Reporters divided by recipients, and clickers divided by recipients	Simulation tool. Security Awareness Lead, after each simulation	Pre launch simulation. Reports doubled, clicks halved by month 12	Rising reports show a healthier culture. A fall means reporting is hard or staff fear blame
3 Payment verification (Risk 1). Sampled payments with call back and second approver divided by payments sampled	Finance audit. Finance Controller, monthly	First audit before launch. 90% by month 6	A rise means the safer procedure is routine
4 Multi factor and password reuse (Risk 2). Accounts with multi factor divided by active accounts, plus count of reused or breached passwords	Identity system. IT Security Lead, monthly	Identity system figures. 95% coverage, 75% fewer reused accounts by month 6	A stolen password is less likely to spread

5 Data incidents and reporting speed (Risk 3). Human error incidents per quarter, and share reported within 24 hours	Incident log. Data Protection Contact, quarterly	Past 12 months. 30% fewer incidents by month 12, 90% reported within 24 hours	Counts may rise early as reporting improves. Speed improves first, then the count falls
6 Fraud outcomes (Risk 1). Attempts received, share caught before payment, value lost	Finance records. Finance Controller, quarterly	Past 12 months. 95% caught before payment, no rise in losses	Attempts may stay level, so the share caught is the key figure

Reporting to leadership. The Security Awareness Lead sends the sponsor a one page report each quarter, with a monthly update to the security manager. Each report compares every metric to its baseline and target, with a headline in plain risk language, what it means, limitations and decisions needed. Example: “Payment verification reached 85% against a 90% target, so invoice fraud exposure is falling but not yet controlled.” Limitations: targets are planning choices until the baseline is captured, warehouse staff are poorly covered by email based metrics (attendance and survey results are used instead), incident counts are small, reporting may rise before incidents fall, and results show association, not proof of cause. Decisions requested include release time for warehouse briefings, second approval inside the payment system, mandatory multi factor authentication, and extra support if a target is missed for two consecutive quarters.

Task 5: Improve and sustain

5.1 Quarterly review routine. Held at the end of months 3, 6, 9 and 12 for 60 to 90 minutes, chaired by the Security Awareness Lead. Attendees are the IT Security Lead, Finance Controller, Data Protection Contact, Warehouse Operations Manager and HR Manager. The sponsor joins for decisions at months 6 and 12 (Proposal). The group examines all metrics against baseline and target, repeat clickers by team, incidents and near misses, learner feedback by audience and shift, and earlier actions. Actions go in a shared log with owner, due date and linked risk, kept by the Security Awareness Lead. Each review opens by checking open actions, and unfinished ones go to the sponsor. Content is updated without waiting for the review after a serious incident or near miss (a short alert or toolbox talk within two weeks), a new scam, a change in process or systems, a change in regulation, or a metric missing target for two consecutive reviews.

5.2 Listening to learners. After each activity, staff answer two questions: “Was this useful for your job?” and “What would make it better?” Office staff use an online form. Warehouse staff use a QR code or paper card collected by supervisors. A quarterly listening group of 6 to 8 staff from every audience, including day and night shifts, meets before each review (Proposal). Feedback is summarised by audience and shift and used to improve relevance (job specific examples) and access (timing, format, device). A short “you said, we did” note is shared each quarter.

5.3 Recognising good behaviour. First, anyone who reports a suspicious message, near miss or their own mistake gets a personal thanks within one working day, and each month one anonymous or opted in “good catch” story is shared. Second, each quarter the team with the strongest safer behaviour, such as the highest report rate, is acknowledged at the review and by the sponsor with a small token (Assumption: within budget). Recognition is at team level only, and no one is named for failing a simulation.

Assumptions. The security team (about three people) can access the email security platform, identity system and incident log, and one person can give about 20% of their time. A simulation tool, report button, multi factor authentication and password manager fit existing budget and systems. The sponsor and HR approve the no blame statement. Finance and the data protection contact share baseline records. Warehouse staff can be released for 10 to 15 minute briefings.

Short reflection

The hardest part to design was the warehouse audience. Warehouse staff handle customer data daily but rarely use email, so online modules and phishing click rates did not fit them. I used supervisor led toolbox talks, scenario cards and a QR code reporting route, which are harder to measure.

The trade off was ambition against capacity. Leadership wants fewer incidents within 12 months, but the security team is small. I kept the program light by using existing systems for evidence, giving each objective to the owner who controls the data, and keeping activities short and monthly.

The main uncertainty is that Northbridge has no baseline figures, so my targets are planning choices. I also expect reporting to rise before incidents fall, and would explain this to leadership rather than treat it as failure.

Sources

1. GRC206 course material, Designing a Successful Security Awareness Program (slides) and GRC206 Assignment Handout, Design a Security Awareness Program (Northbridge Logistics scenario).
2. ISO/IEC 27001:2022, Annex A, control 6.3, information security awareness, education and training.
3. NIST Special Publication 800-50, Building an Information Technology Security Awareness and Training Program.
4. NIST Special Publication 800-63B, Digital Identity Guidelines: Authentication and Lifecycle Management (guidance on screening passwords against breached lists).
5. UK National Cyber Security Centre, Phishing attacks: dealing with suspicious messages and Phishing attacks: defending your organisation.

12 Month Program Calendar

SAL Security Awareness Lead, ITS IT Security Lead, FC Finance Controller, DPC Data Protection Contact, WOM Warehouse Operations Manager, HR HR Manager, COO sponsor. Every month: toolbox talk (WOM), office tip (SAL), fraud example (FC), onboarding (HR), good catch story (SAL), metrics (SAL, FC, ITS). Q1 to Q4 are the quarterly reviews, each with a listening group.

Month	Main activities	Audiences	Owners	Measurement and review
1	Baselines, simulation 1, start rollout	All staff	SAL, ITS, FC, COO	Baseline captured
2	Finance workshop, head office module	Finance, office	FC, SAL, HR	Reach by audience
3	Remote sales, simulation 2, safer team	Remote sales, office	SAL	Reach 90%, Q1 review
4	Coaching for repeat clickers	Teams flagged	SAL	Monthly metrics
5	Finance workshop, simulation 3	Finance, office	FC, SAL	Monthly metrics
6	Remote sales, rollout done, safer team	Remote sales, all	SAL, ITS	Obj 1 and 2, Q2 review
7	Simulation 4, refresh content	Office staff	SAL	Monthly metrics
8	Finance workshop, warehouse data talk	Finance, warehouse	FC, SAL, WOM	Monthly metrics
9	Remote sales, simulation 5, safer team	Remote sales, office	SAL	Q3 review
10	Refresh weakest risk, review trends	Teams flagged	SAL, DPC	Monthly metrics
11	Finance workshop, simulation 6	Finance, office	FC, SAL	Monthly metrics
12	Remote sales, safer team, year review	All staff, sponsor	SAL, COO	Objective 3, Q4 review